

Indice

Relazione Tecnica di Laboratorio

Configurazione, Gestione e Verifica di un Dominio Active Directory in Ambiente Controllato: il Caso Studio “Epicode.local”

Corso: Sistemistica e Sicurezza delle Infrastrutture IT **Ambito:** Esercitazione pratica di laboratorio – Ambiente virtualizzato isolato **Natura dell'attività:** Didattica, non produttiva, priva di finalità offensive

1. Sintesi Esecutiva

Nel corso dell'esercitazione è stato configurato un dominio Active Directory denominato *Epicode.local*, ospitato su un server con sistema operativo Windows Server 2022 Datacenter (Azure Edition), identificato con il nome host *EpicodeServer*. All'interno del dominio è stata realizzata un'unità organizzativa denominata *Amministrazione*, contenente due utenze nominative (Chiara Rossi e Claudio Foresta) e un gruppo di sicurezza denominato *Paghe*, a cui è stato attribuito il controllo di accesso su una risorsa condivisa contenente dati classificati come sensibili. È stata inoltre predisposta una seconda risorsa, priva di autorizzazioni per il gruppo *Paghe*, allo scopo di verificare la corretta applicazione del principio di segregazione degli accessi. Una postazione client è stata associata al dominio e, tramite l'utenza di Chiara Rossi, sono stati verificati sperimentalmente sia l'accesso consentito alla risorsa autorizzata sia il diniego di accesso alla risorsa non autorizzata, a conferma della corretta implementazione dei controlli di sicurezza pianificati.

2. Introduzione

2.1 Contesto e Finalità Didattica

La gestione sicura delle identità e degli accessi rappresenta uno dei pilastri fondanti della sicurezza informatica in ambito aziendale, come peraltro evidenziato nel documento di riferimento fornito a supporto dell'esercitazione, il quale sottolinea come la protezione dei dati non possa più prescindere da un controllo puntuale e granulare degli accessi alle risorse, indipendentemente dalla provenienza della richiesta. La presente attività si colloca in tale cornice concettuale, traducendo in pratica operativa i principi teorici relativi alla gestione delle identità in ambiente Microsoft Active Directory.

Si precisa, in via preliminare e inequivocabile, che l'intera esercitazione è stata condotta in un ambiente di laboratorio **virtualizzato, isolato e privo di qualsiasi interazione con sistemi di produzione o con reti esterne**. Nessuna delle attività descritte configura un tentativo di accesso non autorizzato a sistemi reali, né comporta l'utilizzo di tecniche offensive nei confronti di terzi. Il nome attribuito per finalità didattiche a una delle postazioni client (*SuperHacker*), riportato nelle figure allegate, costituisce una scelta puramente nominale, priva di qualsivoglia valenza operativa o dimostrativa di capacità intrusive, e viene qui documentato esclusivamente per fedeltà descrittiva rispetto a quanto effettivamente configurato durante l'esercitazione.

2.2 Ambiente di Laboratorio

L'infrastruttura di laboratorio è stata realizzata mediante macchine virtuali gestite tramite il software di virtualizzazione Oracle VirtualBox, secondo lo schema sintetizzato nella Tabella 1.

Componente	Ruolo	Sistema Operativo	Dominio/Rete
EpicodeServer	Domain Controller / Server AD DS	Windows Server 2022 Datacenter (Azure Edition)	Epicode.local — 192.168.50.10
Postazione Client	Workstation associata al dominio	Windows 10 Pro N, versione 22H2	Epicode.local

3. Obiettivi dell'Esercitazione

Sulla base della consegna fornita, gli obiettivi formativi dell'esercitazione sono stati così identificati:

1. Completare e verificare la configurazione di rete, il nome del computer e l'associazione al dominio del server, secondo quanto illustrato in sede di lezione.
2. Verificare che le impostazioni configurate risultassero corrette e pienamente funzionanti.
3. Effettuare l'accesso al sistema mediante le credenziali dell'utenza di Chiara Rossi.
4. Verificare che l'utenza di Chiara Rossi disponesse dell'accesso alle risorse coerenti con il proprio ruolo organizzativo, e che tale accesso fosse correttamente delimitato rispetto alle risorse non pertinenti.
5. Documentare fotograficamente ogni fase significativa del processo, a supporto della tracciabilità e della verificabilità dell'esercitazione.

4. Ambiente di Laboratorio e Vincoli Etici

Coerentemente con i principi di condotta responsabile richiamati nella letteratura di settore, l'attività è stata condotta nel pieno rispetto dei seguenti vincoli:

- **Isolamento della rete:** l'ambiente virtuale non è stato esposto a reti pubbliche né collegato a infrastrutture reali.
 - **Finalità esclusivamente formativa:** nessuna delle configurazioni realizzate è stata impiegata, né è destinata a essere impiegata, al di fuori del contesto didattico.
 - **Assenza di dati reali:** tutte le utenze, i nominativi e i contenuti delle cartelle condivise sono fittizi e privi di riferimento a persone o organizzazioni realmente esistenti.
 - **Tracciabilità delle operazioni:** ogni passaggio è stato documentato tramite acquisizione di schermate, al fine di garantire la riproducibilità e la verificabilità dell'esercitazione da parte del corpo docente.
-

5. Metodologia Operativa

L'esercitazione è stata condotta seguendo un approccio strutturato in cinque fasi sequenziali, ciascuna delle quali corrisponde a un macro-obiettivo della consegna: verifica preliminare della configurazione del server, progettazione della struttura organizzativa in Active Directory, definizione delle risorse condivise e dei relativi permessi, associazione del client al dominio e, infine, verifica sperimentale dei privilegi mediante autenticazione con l'utenza target. Tale impostazione metodologica consente di ricondurre ciascuna evidenza fotografica a una precisa fase del processo, favorendo la tracciabilità e la valutabilità dell'elaborato secondo un criterio di corrispondenza puntuale tra azione svolta e obiettivo dichiarato.

6. Fase 1 – Verifica della Configurazione del Server

È stata anzitutto verificata, tramite la console *Server Manager*, la corretta configurazione delle proprietà locali del server. Come riportato in **Figura 1**, il server risulta correttamente identificato con nome host *EpicodeServer*, associato al dominio *Epicode.local* e configurato con indirizzo IP statico 192.168.50.10. Risultano inoltre attivi il firewall di dominio e la protezione in tempo reale dell'antivirus integrato, elementi che, seppur non oggetto primario della consegna, costituiscono un indicatore positivo dello stato di igiene di base

del sistema.

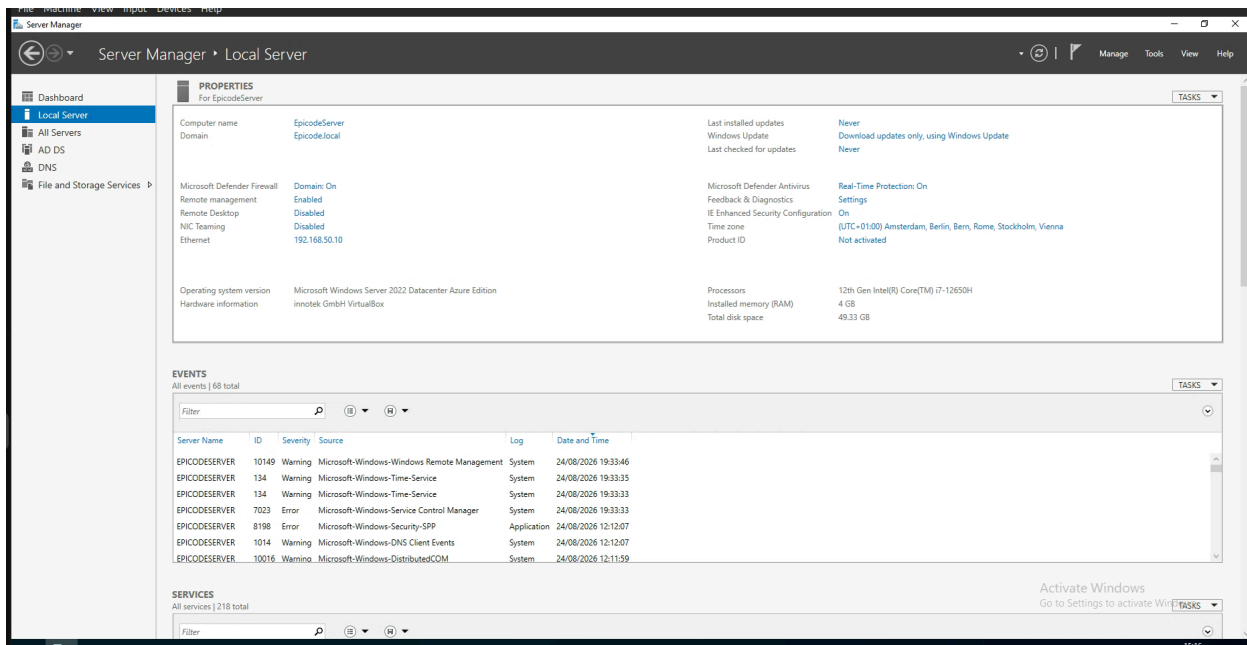


Figura 1 – Pannello *Server Manager* – *Local Server*: riepilogo delle proprietà di sistema del server EPICODESERVER, comprensivo di nome host, appartenenza al dominio Epicode.local, indirizzo di rete, stato dei servizi di protezione (firewall e antivirus Defender) e registro eventi di sistema.

Dall'analisi del registro eventi visibile nella medesima schermata si osserva la presenza di alcuni avvisi (*Warning*) relativi ai servizi di gestione remota e di sincronizzazione oraria, oltre a un errore (*Error*) riconducibile al servizio di controllo dei servizi di sistema. Tali occorrenze, pur non pregiudicando il funzionamento delle componenti oggetto di verifica, sono state annotate a fini di completezza documentale e vengono riprese nella sezione dedicata all'analisi dei rischi.

7. Fase 2 – Progettazione della Struttura di Active Directory

7.1 Struttura del Dominio

La console *Active Directory Users and Computers* (**Figura 2**) mostra la struttura gerarchica del dominio *Epicode.local*, articolata nei contenitori predefiniti (*Builtin*, *Computers*, *Domain Controllers*, *ForeignSecurityPrincipals*, *Managed Service Accounts*, *Users*) e in un'unità organizzativa personalizzata denominata *Amministrazione*, oltre a un ulteriore contenitore denominato *Hacker*, riconducibile — per coerenza con la natura didattica dell'esercizio — a

una struttura dimostrativa priva di implicazioni operative reali.

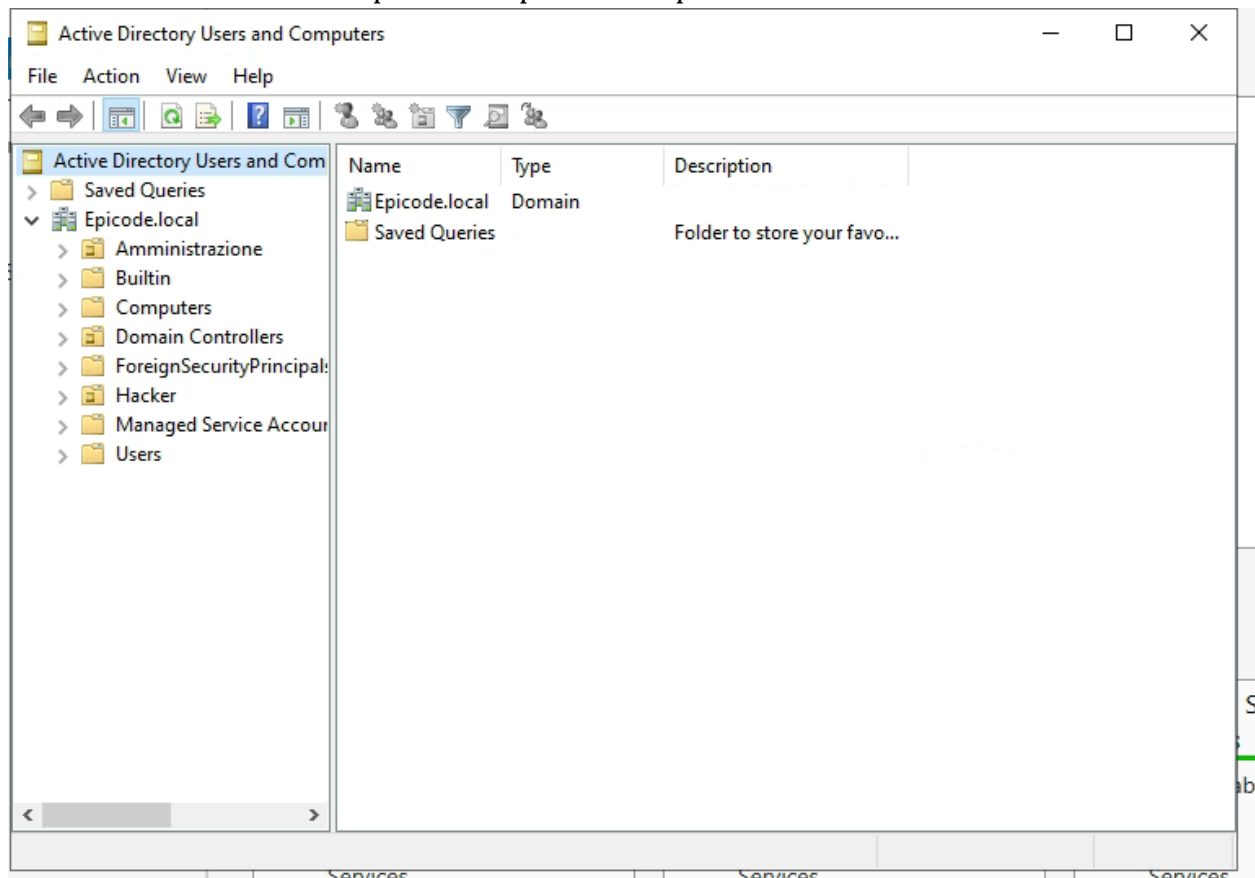


Figura 2 – Vista radice della console *Active Directory Users and Computers*, con evidenza dei contenitori nativi del dominio *Epicode.local* e dell’unità organizzativa personalizzata *Amministrazione*.

7.2 Unità Organizzativa “Amministrazione”

All’interno dell’unità organizzativa *Amministrazione* sono stati censiti due oggetti utente, *Chiara Rossi* e *Claudio Foresta*, e un oggetto di tipo *Security Group* denominato *Paghe* (**Figura 3**), coerentemente con un modello organizzativo che prevede la gestione centralizzata degli accessi tramite gruppi di sicurezza anziché tramite assegnazione diretta dei permessi ai singoli utenti — pratica, quest’ultima, generalmente sconsigliata per ragioni

di manutenibilità e di auditabilità.

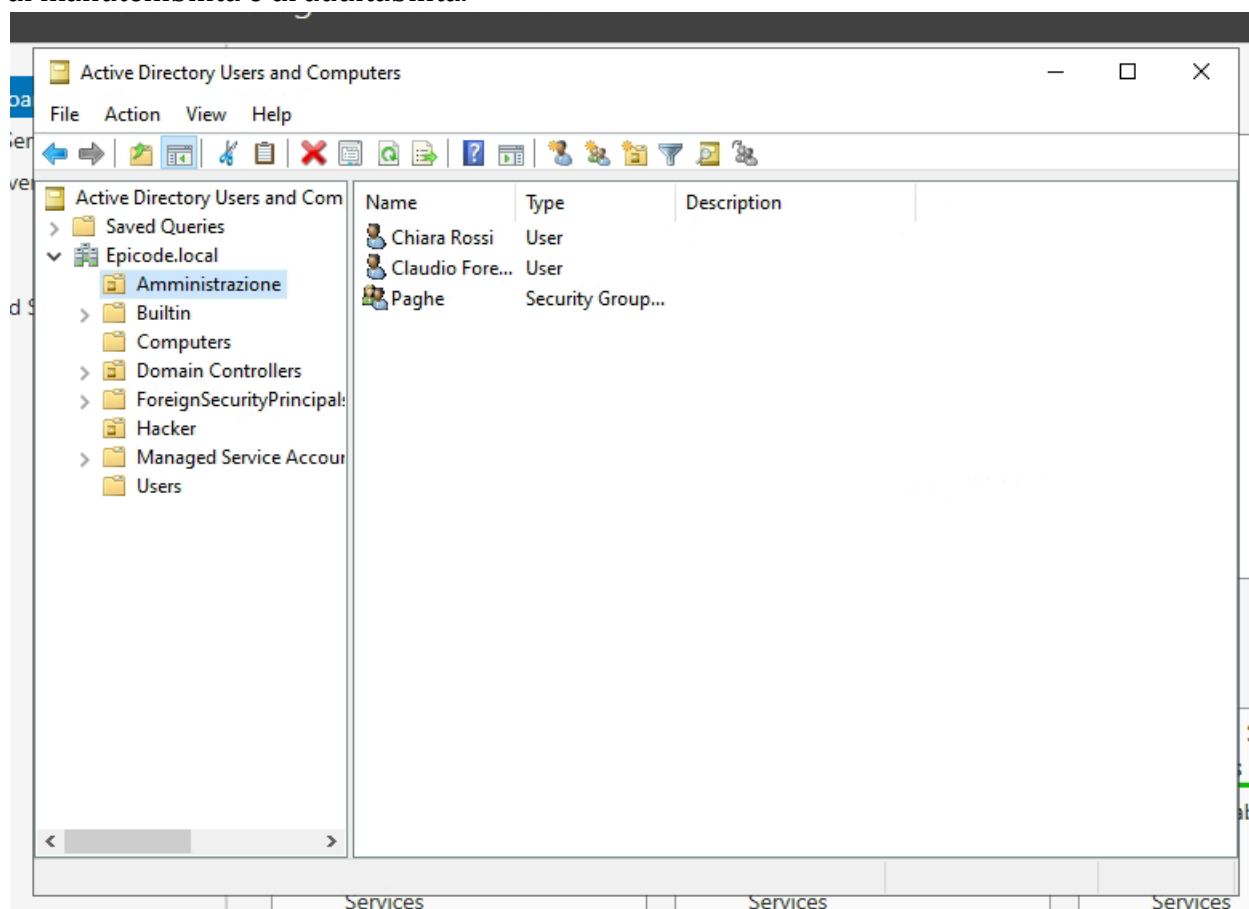


Figura 3 – Contenuto dell'unità organizzativa *Amministrazione*: le utenze *Chiara Rossi* e *Claudio Foresta* e il gruppo di sicurezza *Paghe*.

7.3 Configurazione dell'Utenza "Chiara Rossi"

Le proprietà dell'oggetto utente *Chiara Rossi* sono state esaminate nelle schede *General* e *Account* della relativa finestra di proprietà (**Figure 4 e 5**). È stato verificato che il nome visualizzato (*Display name*) e i dati anagrafici risultassero correttamente valorizzati, e che il nome di accesso (*User logon name*) fosse impostato come *Chiara@Epicode.local*, con il corrispondente nome pre-Windows 2000 *EPICODE\chiara*. Si segnala che nessuna delle opzioni di sicurezza dell'account (quali l'obbligo di cambio password al successivo accesso o la non scadenza della password) risultava selezionata al momento della verifica, aspetto

che viene ripreso criticamente nella sezione 12.

Chiara Rossi Properties

Member Of Dial-in Environment Sessions

Remote control Remote Desktop Services Profile COM+

General Address Account Profile Telephones Organization

 Chiara Rossi

First name: Initials:

Last name:

Display name:

Description:

Office:

Telephone number:

E-mail:

Web page:

Figura 4 – Scheda *General* delle proprietà dell'utente *Chiara Rossi*, con i dati anagrafici e identificativi dell'account.

Chiara Rossi Properties

Member Of	Dial-in	Environment	Sessions
Remote control	Remote Desktop Services Profile	COM+	
General	Address	Account	Profile
Telephones	Organization		

User logon name:
 @Epicode.local

User logon name (pre-Windows 2000):

☐ Unlock account

Account options:

- ☐ User must change password at next logon
- ☐ User cannot change password
- ☐ Password never expires
- ☐ Store password using reversible encryption

Account expires:

☒ Never

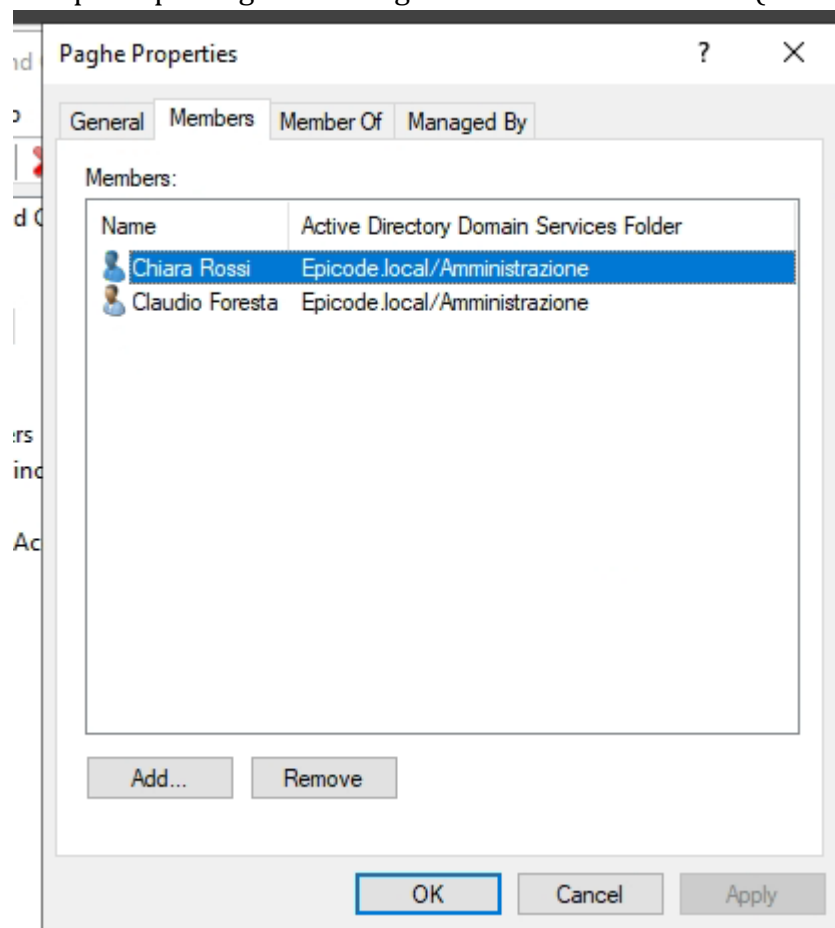
☐ End of:

Figura 5 – Scheda *Account* delle proprietà dell'utente *Chiara Rossi*, con evidenza del nome di accesso, del formato pre-Windows 2000 e delle opzioni relative alla gestione della password e alla scadenza dell'account.

7.4 Configurazione del Gruppo di Sicurezza "Paghe"

La scheda *Members* delle proprietà del gruppo *Paghe* (**Figura 6**) conferma l'appartenenza al gruppo delle utenze *Chiara Rossi* e *Claudio Foresta*, entrambe collocate nell'unità organizzativa *Amministrazione*. Tale configurazione realizza il presupposto logico necessario affinché, in una fase successiva, l'accesso alle risorse condivise possa essere disciplinato mediante l'assegnazione di permessi al gruppo anziché ai singoli account, in

ossequio al principio di gestione degli accessi basata sui ruoli (*Role-Based Access Control*,



RBAC).

Figura 6 – Scheda *Members* del gruppo di sicurezza *Paghe*, con l'elenco nominativo degli utenti *Chiara Rossi* e *Claudio Foresta*.

8. Fase 3 – Configurazione delle Risorse Condivise e dei Permessi

8.1 Struttura delle Cartelle Locali

Sul disco locale del server è stata individuata la cartella radice *Dati Sensibili* (**Figura 7**), collocata direttamente sotto l'unità *C:** e contenente due sottocartelle, *Dati Segreti** e *Dati Tom* (**Figura 8**), destinate a ospitare risorse informative soggette a livelli di riservatezza

differentiati.

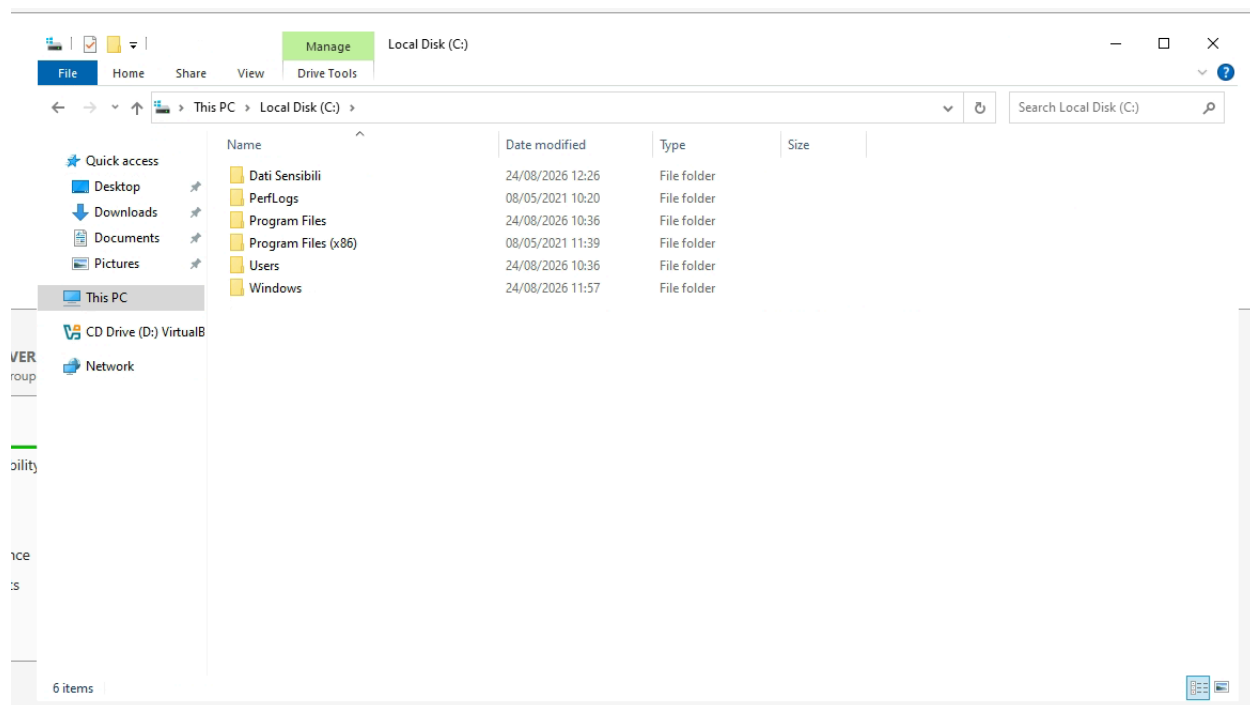


Figura 7 – Struttura della radice del disco locale *C:**, con evidenza della cartella *Dati Sensibili** accanto alle directory di sistema standard.

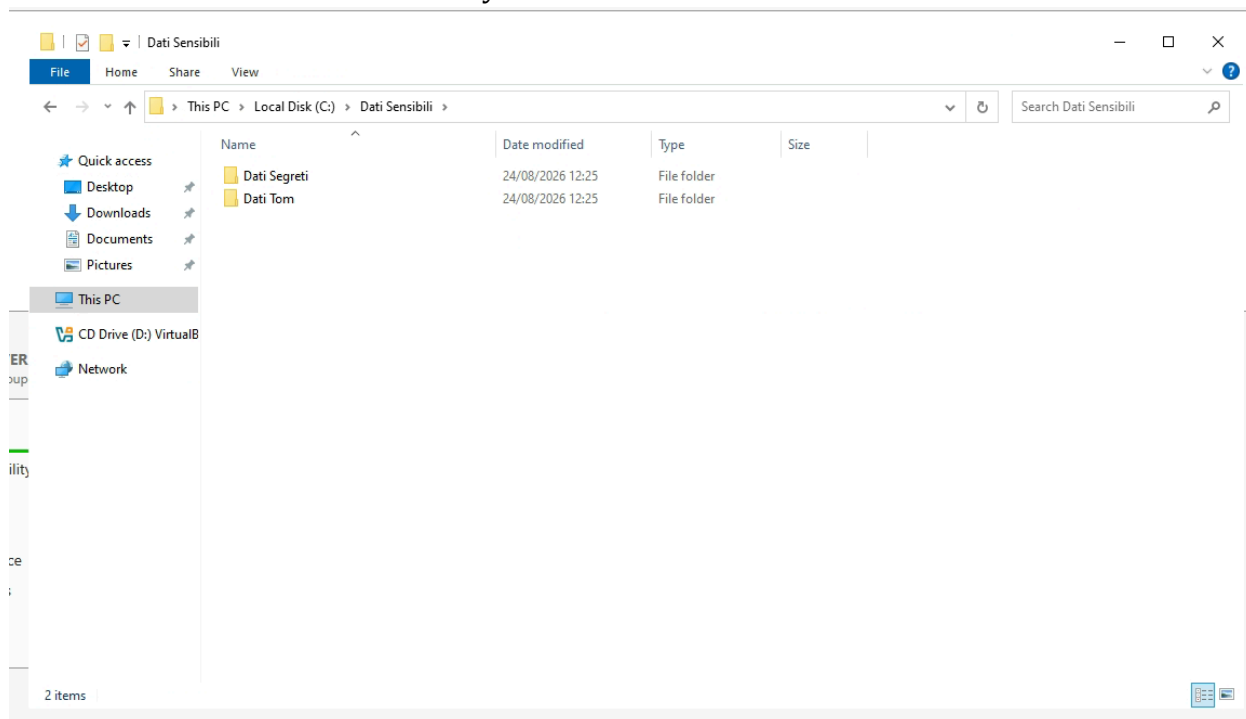


Figura 8 – Contenuto della cartella *Dati Sensibili*, articolato nelle sottocartelle *Dati Segreti* e *Dati Tom*.

8.2 Permessi di Condivisione sulla Cartella “Dati Segreti”

È stata quindi configurata la condivisione di rete della cartella *Dati Segreti*, assegnando al gruppo di sicurezza *Paghe* (identificato come EPICODE\Paghe) i permessi di *Full Control*, *Change* e *Read* in lettura/scrittura (**Figura 9**), mentre non risulta assegnato alcun permesso esplicito ad altri utenti o gruppi generici, quali *Everyone*, a garanzia di un accesso circoscritto ai soli membri autorizzati.

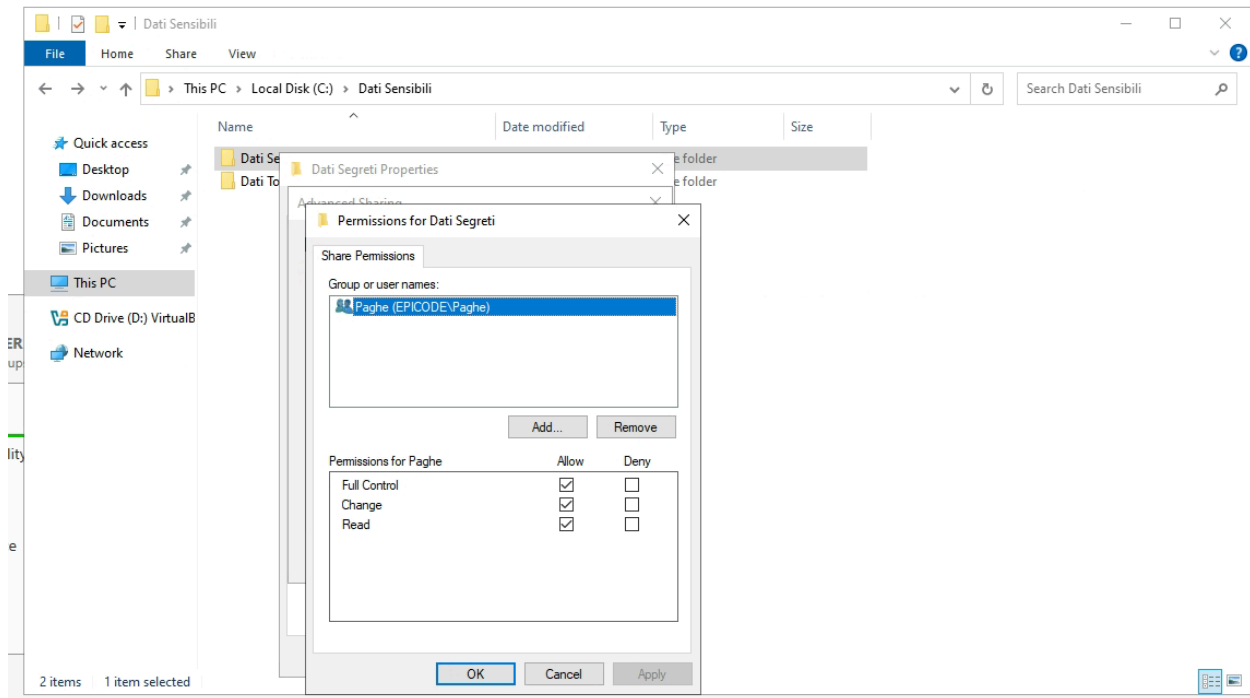


Figura 9 – Finestra *Permissions for Dati Segreti*: assegnazione dei permessi di condivisione di rete (*Full Control*, *Change*, *Read*) al gruppo *Paghe* (*EPICODE*).

La scheda *Sharing* delle proprietà della medesima cartella (**Figura 10**) conferma l’attivazione della condivisione di rete, con percorso UNC pubblicato come \\EPICODESERVER\Dati Segreti, accessibile dagli host membri del dominio secondo le

regole di autorizzazione precedentemente illustrate.

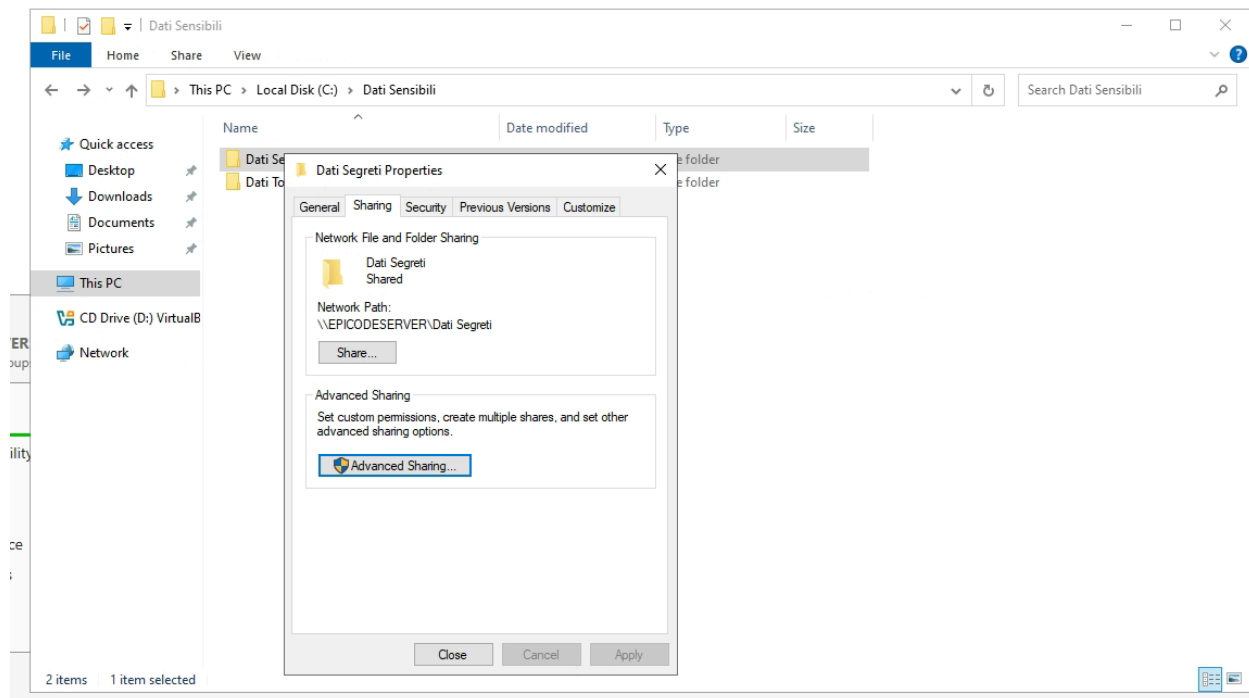


Figura 10 – Scheda *Sharing* delle proprietà della cartella *Dati Segreti*, con indicazione del percorso di rete condiviso e accesso alle opzioni di condivisione avanzata.

Si osserva, a fini di completezza analitica, che la cartella *Dati Tom* non risulta oggetto di un’analoga configurazione documentata nelle evidenze raccolte, circostanza che — come emerge nella successiva fase di verifica — si traduce nell’assenza di permessi assegnati al gruppo *Paghe* su tale risorsa, e dunque nell’impossibilità per Chiara Rossi di accedervi.

9. Fase 4 – Associazione della Postazione Client al Dominio

Prima di procedere alla verifica operativa, è stata completata la configurazione della postazione client. Dal pannello *Impostazioni > Sistema > Informazioni* (**Figura 11**) risulta che il sistema operativo installato è Windows 10 Pro N, versione 22H2, con build del

sistema operativo 19045.2965.

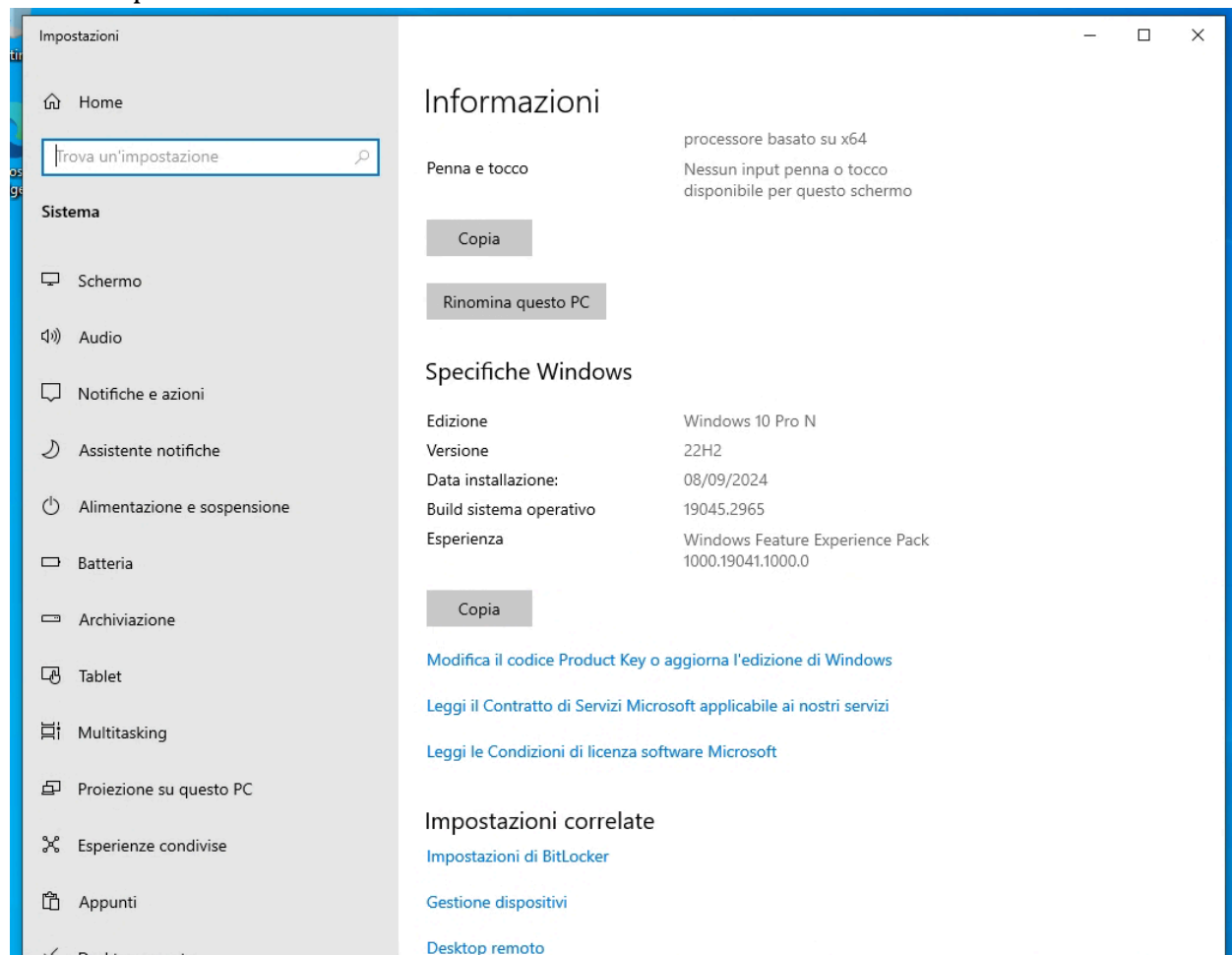


Figura 11 – Pannello *Informazioni* di sistema della postazione client, con le specifiche del sistema operativo installato (edizione, versione e build).

Successivamente, tramite la finestra *Proprietà del sistema*, è stato modificato il nome della postazione (per finalità dimostrative denominata *SuperHacker* nell'ambito dell'esercizio) e ne è stata effettuata l'associazione al dominio *Epicode.local*, con conseguente formazione del nome completo del computer *SuperHacker.Epicode.local* (**Figura 12**). Tale operazione richiede, per essere completata, l'inserimento di credenziali con privilegi di join al dominio, a conferma dell'applicazione di un controllo di accesso anche in questa fase

preliminare del processo.

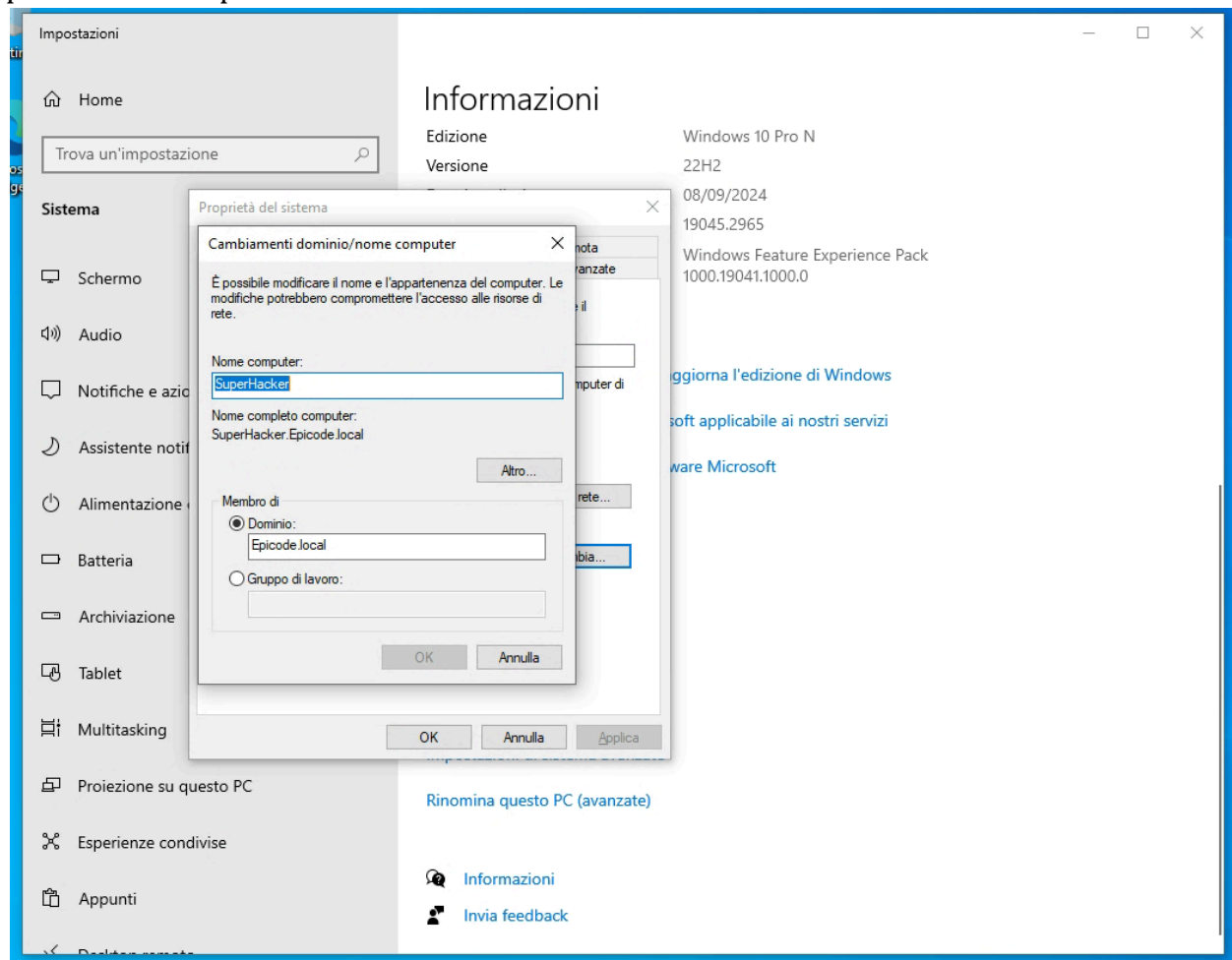


Figura 12 – Finestra *Cambiamenti dominio/nome computer*, con impostazione del nome host e associazione della postazione client al dominio *Epicode.local*.

10. Fase 5 – Verifica Operativa con l’Utenza di Chiara Rossi

10.1 Autenticazione

Una volta completato il riavvio della postazione a seguito dell’associazione al dominio, è stato effettuato l’accesso al sistema utilizzando le credenziali dell’utenza *Chiara Rossi*, come documentato dalla schermata di login riportata in **Figura 13**, nella quale l’account risulta

correttamente proposto come utente predefinito della postazione dominio-joined.

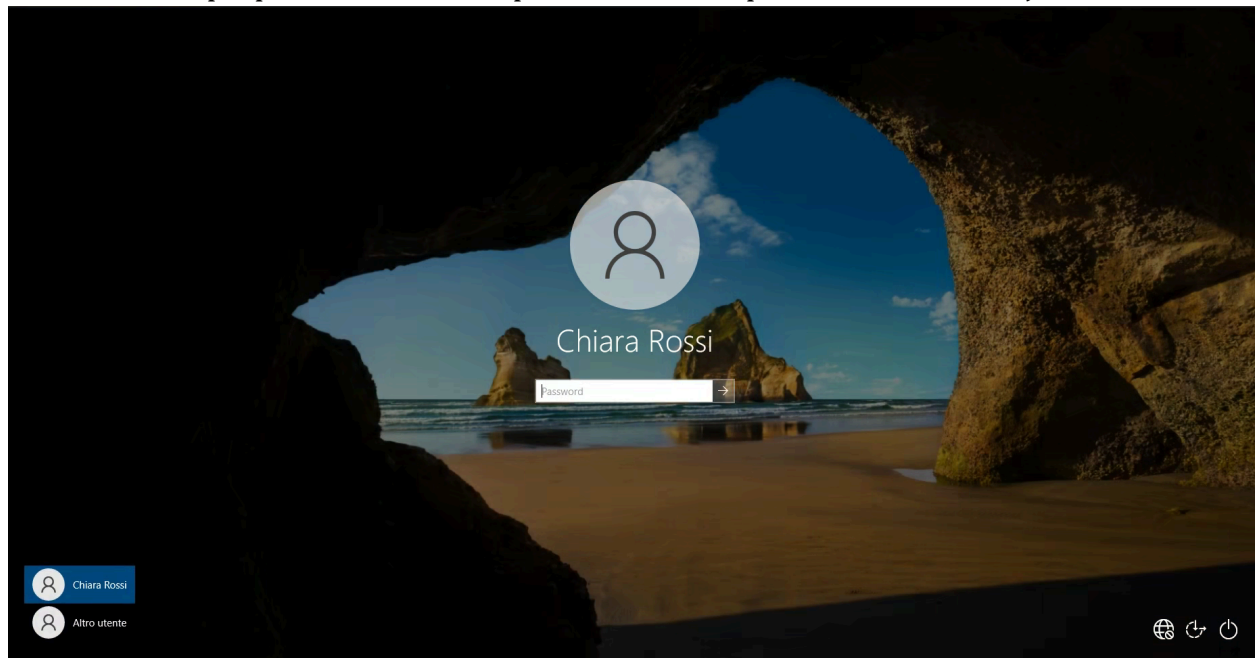


Figura 13 – Schermata di autenticazione di Windows con l’account di dominio *Chiara Rossi*, a conferma della corretta propagazione dell’identità dal Domain Controller alla postazione client.

10.2 Accesso alle Risorse di Rete

Dopo l’autenticazione, è stata effettuata la navigazione delle risorse di rete pubblicate dal server *EPICODESERVER.Epicode.local*, tramite Esplora File. Come mostrato in **Figura 14**, risultano visibili quattro condivisioni: *Dati Segreti*, *Dati Tom*, *NETLOGON* e *SYSVOL*, queste

ultime due generate automaticamente dal ruolo di Domain Controller.

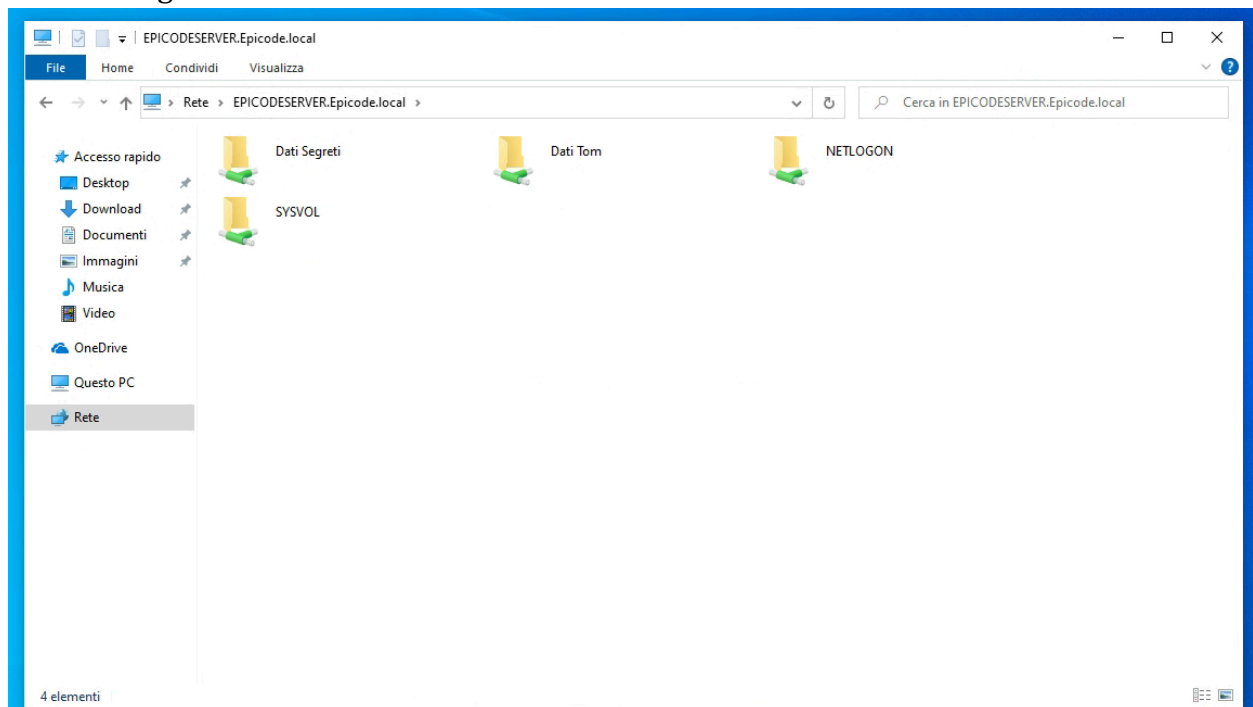


Figura 14 – Elenco delle risorse condivise pubblicate dal server di dominio, visibili dalla postazione client autenticata con l'utenza *Chiara Rossi*.

10.3 Verifica dell'Accesso Autorizzato

L'accesso alla cartella condivisa *Dati Segreti* è stato effettuato con esito positivo (**Figura 15**), confermando che l'appartenenza dell'utenza *Chiara Rossi* al gruppo *Paghe* risulta correttamente propagata e applicata in fase di autorizzazione. La cartella si presenta vuota al momento della verifica, circostanza compatibile con un ambiente di laboratorio privo di

dati reali.

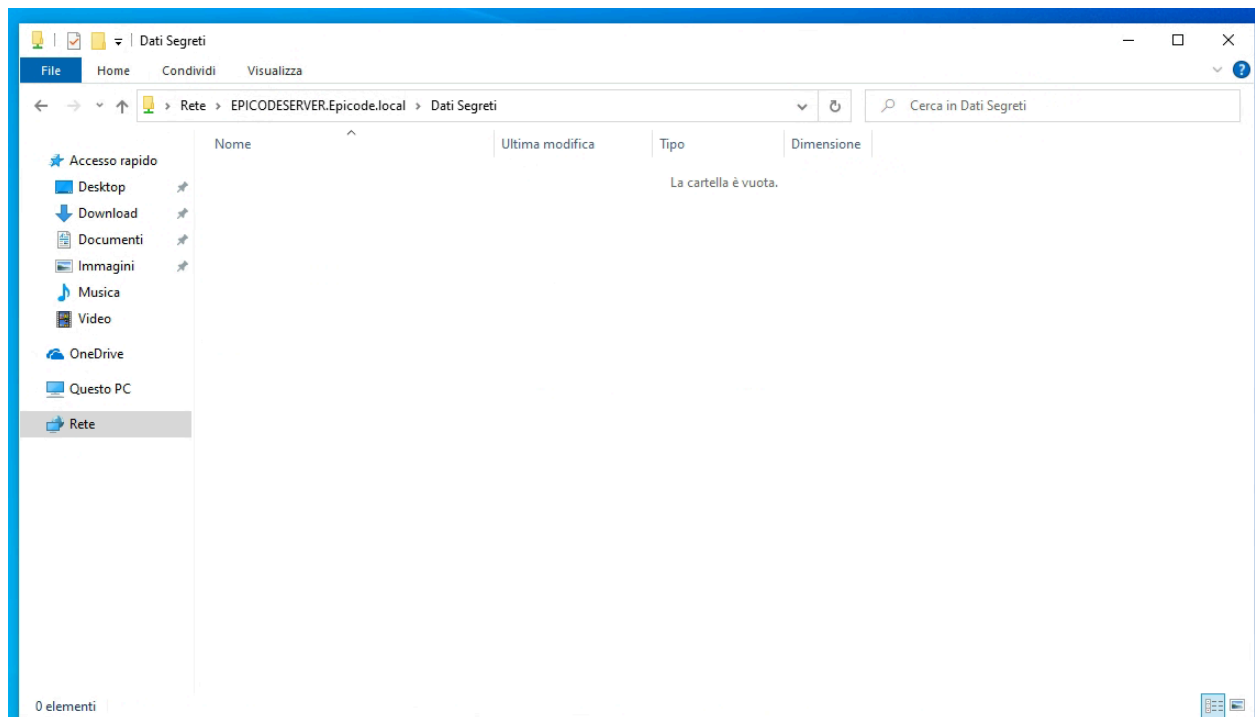


Figura 15 – Accesso consentito alla risorsa condivisa *Dati Segreti* da parte dell'utenza *Chiara Rossi*, in coerenza con l'appartenenza al gruppo di sicurezza *Paghe*.

10.4 Verifica del Accesso Non Autorizzato

Per contro, il tentativo di accesso alla cartella *Dati Tom* ha determinato la comparsa di un messaggio di errore di rete, con testo esplicativo indicante autorizzazioni insufficienti per l'accesso alla risorsa `\\EPICODESERVER.Epicode.local\Dati Tom` (**Figura 16**). Tale esito conferma, in senso complementare rispetto alla verifica precedente, la corretta applicazione del principio di segregazione degli accessi: l'utenza di Chiara Rossi, pur autenticata nel dominio, non dispone di alcun permesso esplicito su risorse non pertinenti

al proprio ruolo.

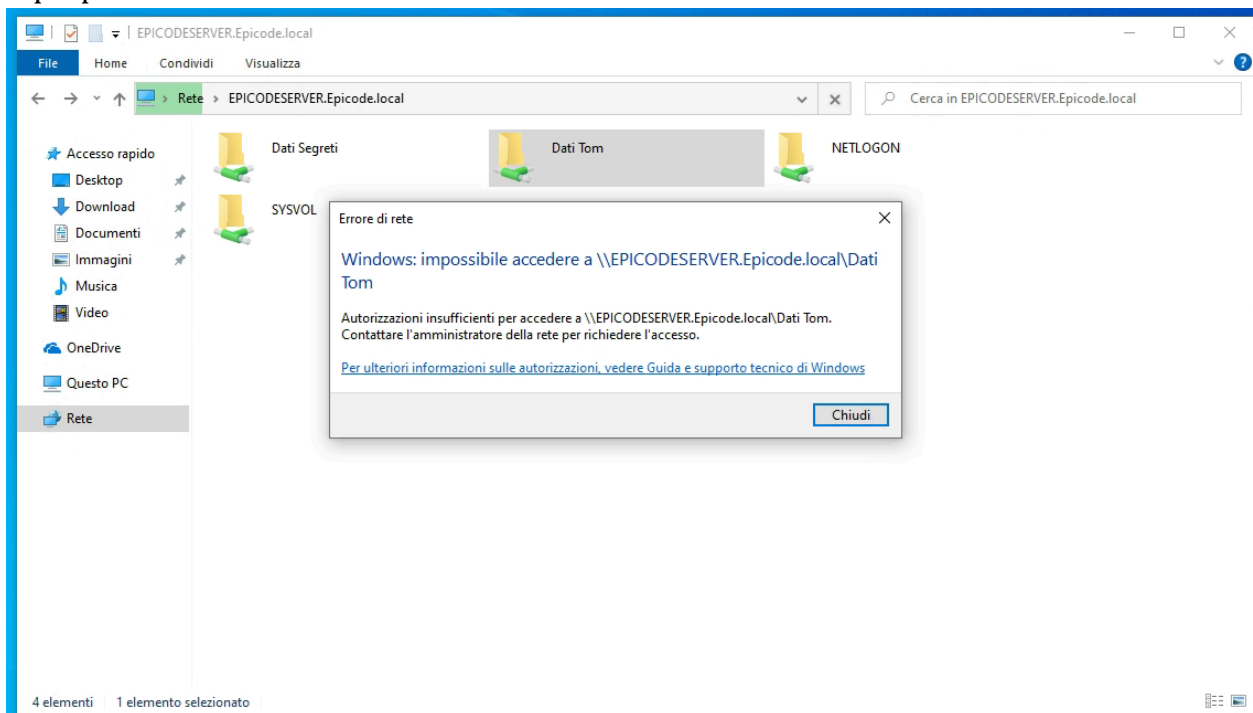


Figura 16 – Messaggio di errore *Windows: impossibile accedere a \\EPICODESERVER.Epicode.local\\Dati Tom*, a riprova dell'assenza di autorizzazioni per l'utenza *Chiara Rossi* su tale risorsa.

11. Considerazioni Finali e Lezioni Apprese

L'esercitazione condotta ha consentito di consolidare, in un contesto pratico e riproducibile, le competenze fondamentali relative alla progettazione e alla verifica di un modello di controllo degli accessi basato su Active Directory. L'evidenza sperimentale raccolta — in particolare il contrasto tra l'accesso consentito alla risorsa *Dati Segreti* e il diniego di accesso alla risorsa *Dati Tom* — dimostra in modo inequivocabile l'efficacia pratica del principio del privilegio minimo quando correttamente implementato mediante gruppi di sicurezza, e costituisce una conferma empirica di un principio che, nella teoria della sicurezza informatica, viene spesso enunciato ma non sempre adeguatamente verificato in sede applicativa.

Al contempo, l'analisi critica condotta nella sezione 12 ha permesso di evidenziare come una configurazione funzionalmente corretta non sia, di per sé, sufficiente a garantire un livello di sicurezza adeguato a un contesto di produzione: la gestione delle credenziali, l'allineamento tra permessi di condivisione e permessi NTFS, il monitoraggio degli eventi di sistema e la disciplina degli aggiornamenti costituiscono dimensioni ulteriori, complementari rispetto alla mera corretta configurazione dei permessi, che un amministratore di sistema è chiamato a presidiare con continuità.

Sul piano formativo, l'esercitazione ha altresì evidenziato l'importanza di una documentazione rigorosa e tracciabile delle attività svolte, quale strumento non solo di verifica didattica, ma anche di buona prassi professionale, trasferibile al contesto reale della gestione di infrastrutture IT aziendali, ove la capacità di documentare in modo puntuale le configurazioni adottate costituisce un requisito imprescindibile ai fini della *accountability* e della conformità normativa.

In conclusione, l'attività svolta ha permesso di tradurre in competenza operativa concreta i principi teorici della gestione sicura delle identità e degli accessi, confermando come la sicurezza informatica non debba essere intesa come uno stato statico da raggiungere una tantum, bensì come un processo continuo di verifica, adeguamento e miglioramento, la cui efficacia dipende in misura non trascurabile dalla preparazione tecnica e dalla disciplina metodologica di chi è chiamato a progettare e a mantenerla nel tempo.